

PROPOSAL PACKAGE | DOCUMENT 08

Security, Privacy and Governance

Access control, audit, data residency, Malaysian and Philippine data protection compliance, AI governance and the human-in-the-loop guarantee

Document	08 of 15
Audience	Client CISO, legal and compliance, IT; delivery team
Version	1.0 (first-meeting edition)
Date	September 2026
Classification	Confidential - prepared for the client

Contents

1. Summary..... 3

2. Security architecture..... 3

 2.1 Identity and access..... 3

 2.2 Data protection in transit and at rest..... 3

 2.3 Application security..... 3

 2.4 Audit and non-repudiation..... 4

 2.5 Availability and resilience..... 4

3. Data residency and sovereignty..... 4

 3.1 The question the client will ask..... 4

 3.2 Deployment patterns..... 5

 3.3 Recommended approach..... 5

4. Data protection landscape (2026)..... 5

5. Privacy by design in the CRM..... 6

6. AI governance..... 7

7. Compliance roadmap by tier..... 7

8. Responsibilities..... 8

1. Summary

The platform is designed so that **the client owns everything** (accounts, code, data), **every action is attributable** (who saw what, who approved what), **data location is a policy choice** (managed cloud in Malaysia or Singapore through fully sovereign hosting), and **no AI action reaches the outside world without a human** (outreach approval gate).

This document is not legal advice. It sets out the controls we will build and the regulatory landscape as we understand it in 2026, so that the client's legal and compliance teams can confirm the approach for their jurisdictions.

2. Security architecture

2.1 Identity and access

- Single sign-on through the client's identity provider (OpenID Connect); multi-factor authentication enforced there.
- Role-based access: executive, relationship manager, approver, analyst, administrator, auditor (read-only). Roles can be scoped to a category or business unit.
- Document-level access lists mirrored from the source (for example SharePoint permissions) or set on upload; enforced in the database with row-level security and applied before retrieval, so the model never sees a passage the user cannot read.
- Relationship-level ownership; managers see their portfolio, leadership sees all; configurable.
- Session timeouts, device and IP logging, administrative actions requiring re-authentication.

2.2 Data protection in transit and at rest

- TLS 1.2 or higher everywhere, including service-to-service calls.
- Encryption at rest for database, object storage and backups using provider-managed keys; customer-managed keys (KMS/Key Vault, HSM-backed) at enterprise tier.
- Secrets in a managed vault; never in code or configuration files; rotated.
- Anti-malware scanning of every uploaded file before parsing; parsers run in isolated workers with no outbound network access.

2.3 Application security

- Secure development lifecycle: code review, dependency scanning, container scanning, static analysis in CI; signed images in production.
- OWASP ASVS-aligned controls: input validation, output encoding, CSRF protection, rate limiting, security headers.
- Prompt-injection defence for the assistant: retrieved document text is delimited and treated as data; system instructions are not overridable by document content; suspicious instruction-like passages are flagged at ingestion.
- Annual third-party penetration test; findings tracked to closure.

2.4 Audit and non-repudiation

- Append-only audit table with hash chaining: each event stores the hash of the previous event, and the chain is anchored daily (for example to object storage with object lock). Tampering is detectable.
- Events recorded: login, document view, question asked (with retrieved passages and answer), finding created or resolved, record created or changed, stage change, outreach draft, submission, approval or rejection, send, connector sync, configuration change, export.
- Auditor role with read-only access and export to the client's SIEM at enterprise tier.

2.5 Availability and resilience

- Automated backups with point-in-time recovery; cross-region copies at enterprise tier; quarterly restore tests.
- Defined RTO and RPO per tier (Document 03, section 11).
- Health checks, alerting, on-call rota at enterprise tier.

3. Data residency and sovereignty

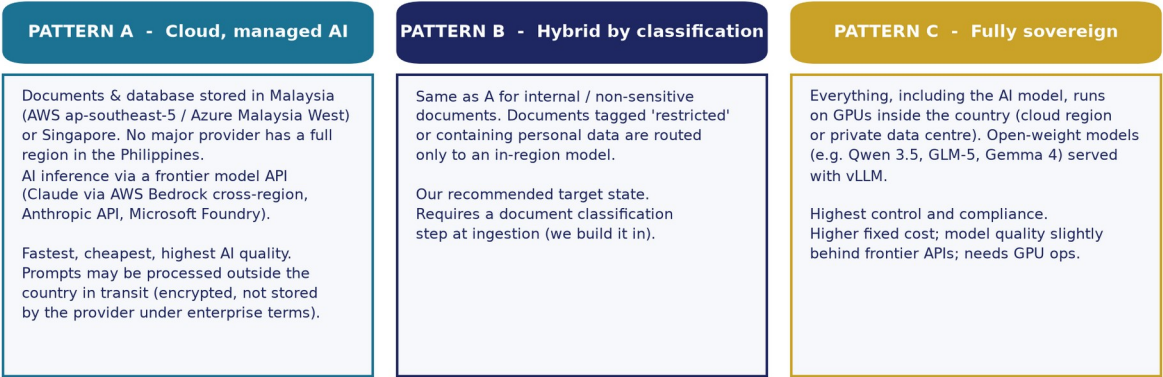
3.1 The question the client will ask

"Where does our data go?" The honest answer has two parts: **data at rest** (documents, database, backups) and **data in processing** (what the AI model sees while answering).

- **Data at rest** can be kept in Malaysia from day one. AWS opened its Asia Pacific (Malaysia) region, ap-southeast-5, in August 2024, and Microsoft made **Azure Malaysia West** generally available in May 2025, both with three availability zones; a second Malaysian Azure region has been announced. So "our data stays in Malaysia" is a commitment that can actually be met.
- **For the Philippine entity the honest answer is different.** None of the major providers operates a full cloud region in the Philippines. AWS runs a **Local Zone in Manila**, which is a latency extension of the Singapore region rather than a region in its own right, and Azure and Google Cloud both serve the Philippines from **Singapore**. Philippine data therefore sits in Singapore or in Malaysia unless the client hosts it themselves. We would rather say this now than discover it during a compliance review.
- **Data in processing** depends on the model route. As of early 2026, Claude models are reached through Amazon Bedrock using **cross-region inference**, which may process a request outside the country it was sent from, in transit, encrypted, without storage, under AWS enterprise terms. Microsoft Foundry's Claude deployments are "Global Standard". Google Cloud's Claude endpoints are US and EU multi-region. A frontier model with an endpoint pinned inside Malaysia or the Philippines was not confirmed at the time of writing, and this should be re-checked at discovery because availability changes quickly.
- For processing that must stay in a named country, the platform routes to open-weight models hosted on GPUs in that country (Pattern C), at a cost and quality trade-off documented in Document 03 and Document 05.

3.2 Deployment patterns

Where the data and the AI model live: three deployment patterns



The model gateway makes the pattern a configuration choice, not a rebuild: the same application code talks to any model.
Recommendation: start on Pattern A for the demo, design for B, keep C as a documented upgrade path.

Deployment patterns

3.3 Recommended approach

Classify documents at ingestion (public, internal, confidential, restricted), record the personal-data status, and record **which entity and country the record belongs to**. Route by policy: restricted and personal-data documents to in-region processing; everything else to the frontier model. This delivers most of the quality at most of the compliance, and is a configuration setting in the model gateway.

Our suggested starting point, to be confirmed with the client's legal contact: store everything in **Azure Malaysia West or AWS ap-southeast-5**, treat the Singapore fallback as the documented alternative for Philippine workloads that need it, and record a transfer assessment for the Philippines-to-Malaysia flow. Because residency is a routing policy rather than an architectural choice, adding a **GCC region later, when the GCC entity begins trading, is a configuration change and not a rebuild**.

4. Data protection landscape (2026)

The client's operations are in **Malaysia** and the **Philippines**, with a **GCC** entity being established. The two operating jurisdictions drive the design today; the GCC is a forward-looking consideration and is included so that entering that market does not require rework.

Jurisdiction	Primary law and regulator	Points relevant to this project
Malaysia	Personal Data Protection Act 2010 as amended by the Personal Data Protection (Amendment) Act 2024, with the principal amendments in force from 1 June 2025; Personal Data Protection Commissioner (JPDP). Cross Border Personal Data Transfer Guidelines issued 29 April 2025.	Four changes matter here. A Data Protection Officer must be appointed by organisations processing personal data at scale or carrying out regular and systematic monitoring, and the duty now reaches processors as well as controllers. A personal data breach must be notified to the Commissioner within 72 hours of the breach occurring (not 72 hours from when you conclude it is serious), and affected

Jurisdiction	Primary law and regulator	Points relevant to this project
		individuals within 7 days of that notification. The old approved-country whitelist has been replaced by a risk-based adequacy test, with a transfer impact assessment expected to evidence it. The penalty ceiling is now RM1,000,000 per offence, with imprisonment available for responsible officers.
Philippines	Data Privacy Act of 2012 (Republic Act 10173) and its implementing rules; National Privacy Commission (NPC). NPC Advisory No. 2024-01 on model contractual clauses, issued 30 May 2024.	Registration of data processing systems and appointment of a Data Protection Officer; security incident notification to the NPC and affected data subjects within 72 hours of knowledge of a qualifying breach. Cross-border transfer is permitted where the transferring organisation remains accountable and the data receives a comparable level of protection. The NPC's model contractual clauses are voluntary and encouraged rather than mandatory, and the NPC does not review agreements for conformity, so the accountability sits with the client. A Privacy Impact Assessment is the expected evidence for a new system of this kind.
GCC (future)	Applies only once the GCC entity begins to process personal data there. Saudi PDPL (SDAIA), UAE Federal Decree-Law No. 45 of 2021, and the separate DIFC and ADGM regimes are the ones most likely to be relevant.	Not in scope for the first release on our current understanding. The point to note is structural: each of these regimes restricts cross-border transfer in some form, so the per-record jurisdiction field and the policy-based routing described in section 3 are what make entry into that market a configuration exercise. We would confirm the position with local counsel before the entity starts trading.

This document is our reading of the position, not legal advice, and the client's own counsel should confirm it. Two points are worth raising early because they change the design rather than the paperwork: whether Philippine personal data may sit in Singapore or Malaysia, and whether a single DPO can cover both operating entities.

Because the client's relationships span more than one jurisdiction, and will span another when the GCC entity opens, the CRM stores each person's **country, jurisdiction, consent status and source** on the record itself, so that outreach and transfer rules can be applied per record rather than per system.

5. Privacy by design in the CRM

- Lawful basis and consent captured per contact (with source and date); outreach to contacts without recorded consent is flagged for the approver.

- Data minimisation: only fields the business needs; free-text notes are visible to the record owner and roles you configure.
- Retention policies per category; deletion and anonymisation routines; support for data-subject access and erasure requests with an audit record.
- Personal data of individuals is separable from corporate data, so sovereign routing can be applied to it specifically.

6. AI governance

Control	Implementation
Closed domain	System instruction and grounding check prohibit outside knowledge; refusal when evidence is absent
Explainability	Every answer shows its sources and pages; every finding shows both conflicting quotes; every extraction keeps the verbatim quote
Human accountability	Findings have owners and resolution notes; outreach has drafter and approver; nothing is sent automatically
Model change control	Model versions pinned; changes tested against the golden set before release; results recorded
No training on client data	Providers used under enterprise terms; opt-outs and zero- or limited-retention options selected where offered; self-hosting removes third parties entirely
Bias and language fairness	The evaluation set covers every language actually present in the client's corpus, and accuracy is reported separately per language rather than as a single blended figure
Spend and abuse controls	Per-user and per-team budgets, rate limits and anomaly alerts on the gateway
Alignment with frameworks	Controls map to ISO/IEC 42001 (AI management) and the NIST AI Risk Management Framework; Malaysia's National Guidelines on AI Governance and Ethics are referenced for the Malaysian entity

7. Compliance roadmap by tier

Tier	Evidence and certifications
Pilot	Security controls above; provider certifications (SOC 2, ISO 27001) for cloud services; data processing agreements in place
Departmental	Penetration test; documented policies; access reviews quarterly
Enterprise / sovereign	ISO 27001-aligned operations for the platform; a registered Data Protection Officer and a documented transfer impact assessment for each cross-border flow; NPC registration of the processing system for the Philippine entity; SIEM integration; customer-managed keys
Group-scale	Formal certification of the managed service; regular external audits; regulator engagement support

8. Responsibilities

Area	Client	Delivery team / managed service
Cloud account ownership and billing	Owns	Operates under delegated access
Identity provider and user lifecycle	Owns	Integrates
Data classification rules and lawful basis	Decides	Implements and enforces in software
Approval policies and approvers	Decides	Implements
Application security, patching, monitoring	Informed	Owns (managed service)
Incident response	Joint; client notified within agreed hours, set to leave room inside the 72-hour regulatory clock in both jurisdictions	Runs technical response
Regulatory filings and DPO duties	Owns	Provides evidence and reports